补丁来源

不可信

大模型补丁生成

- 本地开源模型
- 独立进程，仅本地回环网络
- 看不到仓库与真实凭据

开发者修订

- 保存为新版本，AI原件保留
- 同一闸门，不能绕过

CredProof 可信验收闸门

验收策略 $\mathcal{P}$

credproof.toml — 由人工声明，模型不可修改

入口 · 可修改范围 M · 允许 / 禁止目录 · 允许服务 · 凭据变量 · 必要测试 T · 场景 S

隔离边界

bubblewrap · 只读根文件系统 · 独立网络 · 空环境变量 · 资源上限

一次性副本
工具 ⊕ Δ，必要测试 T

诱饵凭据 c
每次运行随机生成

受控访问组件
按策略读文件 / GET，不跟随跳转

模拟服务
允许服务（/redirect → 禁止）· 禁止服务

观测层

在加载项目代码之前安装

O_{file}
审计 open → 解析真实路径 → 允许 / 禁止

O_{net}
连接记录 + 服务回执（路径、认证）

O_{leak}
c 出现在返回值 · 输出 · 日志 · 异常

O_{test}
逐用例 pytest：收集 · 执行 · 通过 · 跳过

判定引擎

固定程序 · 基于证据 E 的 14 项谓词

Φ_{safe} 不泄密 · 不越界读取 · 不访问禁止服务

Φ_{obl} 必须读取允许文件 · 必须完成服务认证

Φ_{biz} 必要测试通过 · 场景符合声明

证据不足 — E 不完整：隔离阻断 · 测试跳过 · 场景未触达

不通过 — $\exists \varphi \in \Phi : \varphi(E) = \bot$

通过 — $\forall \varphi \in \Phi : \varphi(E) = \top$

证据绑定

结论与决定对应确切字节

h = H(tree ‖ $\mathcal{P}$ ‖ T ‖ component)

报告 r 适用 当且仅当 r.h = h

版本链 v_0（AI）→ v_1（开发者）→ …

受保护操作 ⟨v, h, H(r), |D|⟩ 必须一致

人工权限与交付

人工采纳

- 只能采纳当前“通过”的版本
- 不能推翻“不通过 / 证据不足”
- 决定只追加，不覆盖

证据包

- Δ、$\mathcal{P}$、测试、组件、报告

独立复检

- 新环境完整重新执行
- 从不读取保存的结论

回归测试 → CI

- 每次提交自动重新验收

仅通过

1 提出补丁 Δ
2 隔离执行 T、S
3 采集证据 E
4 结论 V 绑定 h
5 人工采纳
6 导出证据包
7 新环境重新执行
8 反例反馈

数据流 · 反馈 · 隔离边界 · 不可信